

# CASCADE CIVIC SYSTEMS, INC. — PLAN OF ACTION

GrantBridge Platform (SaaS) | FedRAMP Moderate | Reporting Period: Q1 2026 | Status Dat

| POA&M ID | Weakness Name                                         | Weakness Description                                                                                                                                                                                                                                            |
|----------|-------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V-001    | Untimely Remediation of High-Severity Vulnerabilities | Authenticated vulnerability scans identified 14 High-severity findings that exceeded the FedRAMP 30-day remediation window for Moderate systems. Root cause: patching pipeline lacked automated escalation when an SLA breach was approaching.                  |
| V-002    | Configuration Drift from Approved Hardening Baseline  | Assessment sampling identified three application servers with configuration settings deviating from the approved CIS Level 1 hardening baseline, including a non-compliant SSH configuration and a disabled host-based audit daemon.                            |
| V-003    | Incomplete Logging of Privileged Function Use         | Privileged function execution on the legacy reporting subsystem is not forwarded to the centralized SIEM, creating a gap in the audit trail for administrative actions on that component.                                                                       |
| V-004    | Annual System Recovery Exercise Not Performed         | Full-system recovery and reconstitution procedures have not been exercised within the required annual period. Component-level backup restoration has been tested, but an end-to-end recovery validating documented RTO/RPO has not been conducted.              |
| V-005    | Inconsistent Audit Log Review Evidence                | The documented weekly audit log review procedure was not consistently evidenced for a two-month period. Reviews may have occurred but were not recorded in a manner that supports assessment.                                                                   |
| V-006    | Incident Reporting Timeline Not Exercised             | The one-hour US-CERT and FedRAMP ISSO incident notification requirement is documented in the Incident Response Plan but has not been validated through a tabletop or live exercise, creating uncertainty about the organization's ability to meet the timeline. |
| V-007    | Late Submission of Continuous Monitoring Deliverables | Monthly continuous monitoring deliverables (scan results, POA&M updates, inventory) were submitted after the required deadline in two of the last six reporting cycles.                                                                                         |
| V-008    | Shared Service Account Used by Batch Processing Jobs  | A shared service account with elevated database privileges is used by four batch processing jobs, preventing attribution of database actions to a specific process and violating least-privilege and individual-accountability requirements.                    |

## AND MILESTONES (POA&M)

e: 2026-03-31 | Sample GRC portfolio artifact — fictional company

| Source of Discovery                   | NIST 800-53 Control(s) | Asset Identifier                              | Severity | Likelihood | Impact   |
|---------------------------------------|------------------------|-----------------------------------------------|----------|------------|----------|
| Monthly ConMon Scan / 3PAO Assessment | RA-5, SI-2             | Application Tier (web-app-prod-01 through 06) | High     | High       | High     |
| 3PAO Assessment (Technical Test)      | CM-6                   | app-srv-04, app-srv-07, app-srv-11            | Moderate | Moderate   | Moderate |
| 3PAO Assessment (Technical Test)      | AC-6(9), AU-2          | reporting-svc-legacy                          | Moderate | Moderate   | High     |
| 3PAO Assessment (Interview/Examine)   | CP-10                  | GrantBridge Platform (system-wide)            | Moderate | Low        | High     |
| 3PAO Assessment (Examine)             | AU-6                   | SIEM Platform                                 | Low      | Moderate   | Low      |
| 3PAO Assessment (Interview)           | IR-6, IR-4             | Incident Response Program                     | Moderate | Moderate   | Moderate |
| FedRAMP ConMon Review                 | CA-7                   | ConMon Program                                | Low      | Moderate   | Low      |
| Internal Self-Assessment              | AC-2, AC-6             | grantbridge-batch-db                          | Moderate | High       | Moderate |

| Risk Rating | Point of Contact                 | Remediation Plan                                                                                                                                                                                | Scheduled Completion Date |
|-------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|
| High        | Director of Platform Engineering | Implement automated SLA-based escalation in the vulnerability management pipeline; remediate the 14 open High findings; institute weekly SLA burn-down review.                                  | 2026-06-30                |
| Moderate    | Cloud Infrastructure Lead        | Re-image affected hosts from the approved AMI; enable AWS Config drift detection with automatic remediation for baseline settings; add drift check to deployment gate.                          | 2026-05-31                |
| High        | Security Operations Lead         | Deploy log forwarding agent to the legacy reporting subsystem; validate privileged-action event coverage against the approved auditable events list; confirm SIEM ingestion and alerting.       | 2026-05-15                |
| Moderate    | Director of Infrastructure       | Conduct a full-system recovery exercise in an isolated environment; measure actual RTO/RPO against documented objectives; update the Contingency Plan based on exercise findings.               | 2026-07-31                |
| Low         | Security Operations Lead         | Implement a ticketed workflow that generates an auditable record for each weekly log review, including reviewer, date, findings, and escalations; backfill process documentation.               | 2026-04-30                |
| Moderate    | Incident Response Lead           | Conduct a tabletop exercise specifically testing notification timelines to US-CERT and the FedRAMP ISSO; document actual elapsed times; update the IR Plan and contact roster based on results. | 2026-06-15                |
| Low         | ISSO                             | Automate ConMon deliverable assembly and add calendar-driven internal deadlines five business days ahead of the external due date; assign a documented backup submitter.                        | 2026-05-31                |
| High        | Director of Platform Engineering | Migrate each batch job to a dedicated IAM database role scoped to the minimum required privileges; eliminate the shared account; verify attribution in database audit logs.                     | 2026-08-31                |

| Milestones                                                                                                                                                                    | Status      | Days Open | Overdue? |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------|----------|
| M1: Remediate all open High findings (2026-05-15); M2: Deploy automated SLA escalation (2026-06-15); M3: Validate with clean scan cycle (2026-06-30)                          | In Progress | 30        | No       |
| M1: Re-image affected hosts (2026-04-15); M2: Enable Config auto-remediation rules (2026-05-15); M3: Add pre-deploy drift gate to CI (2026-05-31)                             | In Progress | 30        | No       |
| M1: Deploy forwarding agent (2026-04-20); M2: Validate event coverage (2026-05-05); M3: Confirm SIEM alerting rules fire (2026-05-15)                                         | In Progress | 30        | No       |
| M1: Develop exercise scenario and success criteria (2026-05-30); M2: Execute recovery exercise (2026-07-15); M3: Update Contingency Plan and after-action report (2026-07-31) | Open        | 30        | No       |
| M1: Build ticketed review workflow (2026-04-10); M2: Complete four consecutive evidenced review cycles (2026-04-30)                                                           | In Progress | 30        | No       |
| M1: Develop tabletop scenario (2026-05-01); M2: Execute tabletop with Legal and Communications (2026-06-01); M3: Update IR Plan and roster (2026-06-15)                       | Open        | 30        | No       |
| M1: Automate deliverable package generation (2026-05-01); M2: Establish internal deadline and backup owner (2026-05-15); M3: Two consecutive on-time cycles (2026-05-31)      | In Progress | 30        | No       |
| M1: Inventory required privileges per job (2026-05-30); M2: Create scoped roles and migrate jobs (2026-07-31); M3: Disable shared account and validate logs (2026-08-31)      | Open        | 30        | No       |

**Status Date (input):**

2026-03-31

[illegible]

# POA&M SUMMARY — Q1 2026

Counts derived from the POA&M tab.

| Risk Rating | Open | In Progress | Closed | Total |
|-------------|------|-------------|--------|-------|
| High        | 1    | 2           | 0      | 3     |
| Moderate    | 2    | 1           | 0      | 3     |
| Low         | 0    | 2           | 0      | 2     |
| TOTAL       | 3    | 5           | 0      | 8     |

Overdue Items 0  
Next Milestone Due 2026-04-30

# POA&M — LEGEND

Purpose

Editable input cell

Sources of Discovery

Risk Rating

Traceability

Deviation / Risk Acceptance

Closure

## POA&M ID & METHODOLOGY

The Plan of Action and Milestones is the authoritative tracking document for every security weakness identified in a federal system. It is a required deliverable under FISMA and FedRAMP and is submitted to the Authorizing Official on a monthly continuous monitoring cadence.

Cell U1 on the POA&M tab (yellow) is the Status Date. Change it and the Overdue? column recalculates against every scheduled completion date.

3PAO Assessment | Monthly ConMon Scan | Internal Self-Assessment | Penetration Test | Incident | FedRAMP ConMon Report | Customer-Reported

Derived from Likelihood and Impact. FedRAMP remediation timelines: High = 30 days, Moderate = 90 days, Low = 180 days from discovery.

Each POA&M ID maps back to a control marked 'Other Than Satisfied' in the SCTM, and forward to the findings document in the Security Assessment Report.

Where a weakness cannot be remediated within required timelines, a formal deviation request (Risk Adjustment, False Positive, Operational Requirement) must be submitted to and approved by the Authorizing Official.

A POA&M item may only be closed with evidence of remediation validated by the ISSO — typically a clean scan, a re-test of the assessed artifact.